

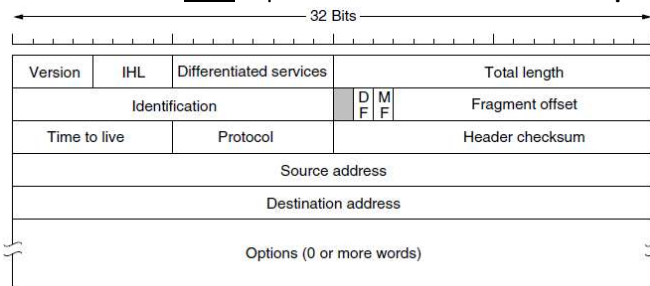
Instructions:

- The exam is in **two** parts: Part 1 consists of 4 questions that require short answers, each is for 5 marks → 20 marks. Part 2 consists of 7 questions that require relatively long answers, each is of 10 marks → 70 marks.
- This is a “closed-book” exam. All necessary information, including tables, etc. will be provided.
- Write your answers in the space provided. If necessary, use a separate sheet for rough work.
- Do not use unfair means. Action will be taken if you use unfair means. This includes using books, computer, phones, etc. or sharing information with other stuE₂ but nothing else.
- In some problems you have to provide details of contents of a message entity A sends to entity B. Here is one example: $A \rightarrow B: \langle E_k(\text{Text}, \text{ID}, \text{N1}) \parallel \text{ETC} \rangle$. The key, K , should **suggest the nature of encryption algorithm**.

Part 1: 4 questions that require short answers of 5 marks each

Q1

1. Assume IIITD establishes a 2nd campus in Noida, and connects the two LANs in Delhi & Noida using the Internet, and then installing an IPSec “tunnel” between the two routers. Before an IP packet exits the egress router in Delhi LAN, it is encrypted & encapsulated within a new IP packet. **Question:** Identify **5 fields** from the original IP header that are **NOT** copied into **IP header of outer IP packet**. **FYI, header of an IPv4 header is shown below.**



1 mark for each correct answer → total 5

- Source Address (Replaced by the Delhi egress router's public IP).
- Destination Address (Replaced by the NOIDA ingress router's public IP).
- Time to Live parameter
- Header Checksum (Must be recalculated entirely for the new outer header).
- Total Length (Recalculated to include the addition of the ESP/AH headers, trailers, and the original packet).

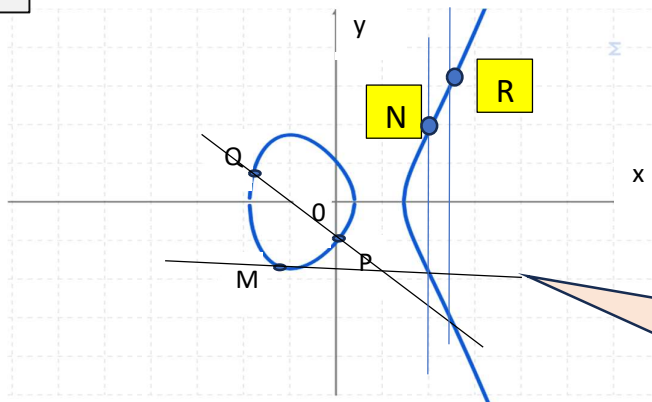
Other possibility: Fragment Offset; Total Length

2. Consider the particular elliptic curve over real numbers $y^2 = x^3 - 2.9x + 1.1$, pictured below. Also shown are three points on the curve, viz. M, P, and Q. On the picture itself indicate where on the curve the resulting points are:

Q2

$$N = 2 \cdot M$$

$$R = P + Q$$



For TA:

To identify $N=2M$: Draw a line tangent to curve M. Find where this tangent intersects curve. Reflect this intersection point across the x-axis to find N.

To identify $R=P+Q$: Draw a line passing through P & Q. Find where this line intersects curve for third time. Reflect this intersection point across the x-axis to find R.

2 marks for $N=2 \cdot M$,
 3 marks for $R=P+Q$
 → total 5

Roll no.: _____

Part 2: Questions 5 to 11 are each 10 marks.

Q5

5. Device **A** wishes to send text, **TX1**, to device **B**, and expects device **B** to reply with an acknowledgment, **AK1**. Device **B** will accept text **TX1**, from **A** and then reply to it with an ack, **AK1**, provided it can verify the origin and integrity of text **TX1** sent by device **A**. Similarly, device **A** will accept the ack **AK1** from device **B** only if it can verify the origin and integrity of the reply, **and** (ii) the ack **AK1** makes a reference to the text **TX1**.

Questions:

- What kind of cryptosystem could devices **A** and **B** be using between them to send/receive/authenticate/verify integrity of text **TX1** or ack **AK1** as per the above requirements?
Public-Key Cryptosystem together with a hash function.
- What information at the very minimum should device **A** possess before it can send text **TX1**?
A must possess A's private key to sign TX1.
- What information at the very minimum should device **B** possess before it can receive/verify text **TX1**?
B must possess A's public key to verify origin and integrity of message TX1.
- What information at the very minimum should device **B** possess before it can send ack **AK1**?
B must possess B's private key to sign AK1.
- What information at the very minimum should device **A** possess before it can receive/verify ack **AK1**?
A must possess B's public key to verify origin and integrity of message AK1.
- What mechanism could devices **A** & **B** be using so that device **B** can make a reference in ack **AK1** to text **TX1**?
A should have included a Nonce, **N1, in TX1 message, while B returns a f(N1) in the AK1 message it sends**
- What is the structure & content of the overall message (with text **TX1** included) that **A** sends to **B**? See example given in "Instructions".
A → B: <E_{PRA}(TX1, N1) || (TX1, N1)>. Public-key encryption using A's private key
- What is the structure & content of the overall message (with ack **AK1** included) that **B** sends to **A**? See example given in "Instructions".
B → A: <E_{PRB}(AK1, f(N1)) || (AK1, f(N1))>. Public-key encryption using B's private key

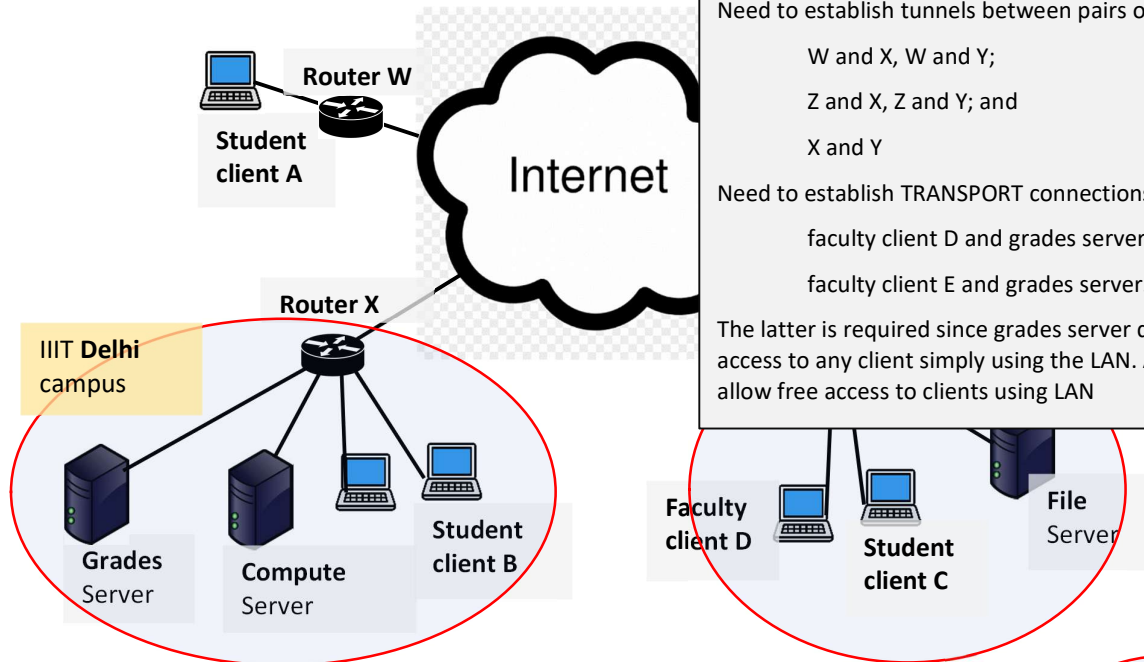
1 mark for each part a. through f.

2 marks for parts g. and h.

→ total 10

Q6

6. Consider establishing IPSEC 'Transport-mode' or IPSEC 'Tunnel-mode' connections between clients, servers and routers (W, X, Y, Z) so as to facilitate clients (A, B, C, D) to access the Grades server, Compute server & File server on the two IIIT campuses in Delhi or NOIDA. See below network connections between clients, servers, & routers.
- Note:** While everyone can access the Compute & File servers on the two campuses, only faculty clients may access the Grades server.
- What kind of IPSEC connection is required to be established between a given pair of devices so that clients (students and faculty) in either campus can access servers in local & remote campuses? **To do so, identify the mode of IPSEC connection in the table below.**

**For TA:**

Need to establish tunnels between pairs of routers:

W and X, W and Y;
Z and X, Z and Y; and
X and Y

Need to establish TRANSPORT connections between:

faculty client D and grades server
faculty client E and grades server.

The latter is required since grades server does not allow access to any client simply using the LAN. All other servers allow free access to clients using LAN

	Router W	Router X	Router Y	Router Z	Compute or File server	Grades server
Student client A					Transport/ Tunnel/ None	Transport/ Tunnel/ None
Student client B					Transport/ Tunnel/ None	Transport/ Tunnel/ None
Student client C					Transport/ Tunnel/ None	Transport/ Tunnel/ None
Faculty client D					Transport/ Tunnel/ None	Transport / Tunnel/ None
Faculty client E					Transport/ Tunnel/ None	Transport / Tunnel/ None
Router W		Transport/ Tunnel / None	Transport/ Tunnel / None	Transport/ Tunnel/ None		
Router X	Transport/ Tunnel / None		Transport/ Tunnel / None	Transport/ Tunnel / None		
Router Y	Transport/ Tunnel / None	Transport/ Tunnel / None		Transport/ Tunnel / None		
Router Z	Transport/ Tunnel/ None	Transport/ Tunnel / None	Transport/ Tunnel / None			

1/2 mark for each correct answer in these two sets → 8 marks

Another 2 marks if the overall scheme is correct

→ 10 marks

Roll no.: _____

Q7

7. **Alice** and **Bob** propose to use **Diffie-Hellman** scheme to generate shared keys as/when necessary. They have also decided to use **ElGamal** Cryptosystem for Bob to encrypt and send to Alice messages **M1** and **M2** but using the concept of **ONE-TIME SHARED KEYS**. The specific Diffie-Hellman scheme uses **prime q** and its **primitive root α** . As and when necessary, Alice and Bob draw and assign random numbers as private keys, **XA**, **XB1** or **XB2**, and compute corresponding public keys **YA**, **YB1**, or **YB2**. Bob computes and sends computed cipher texts **C1** and **C2**. While all this is fine, Alice and Bob must prevent an intruder from launching a man-in-the-middle attack.

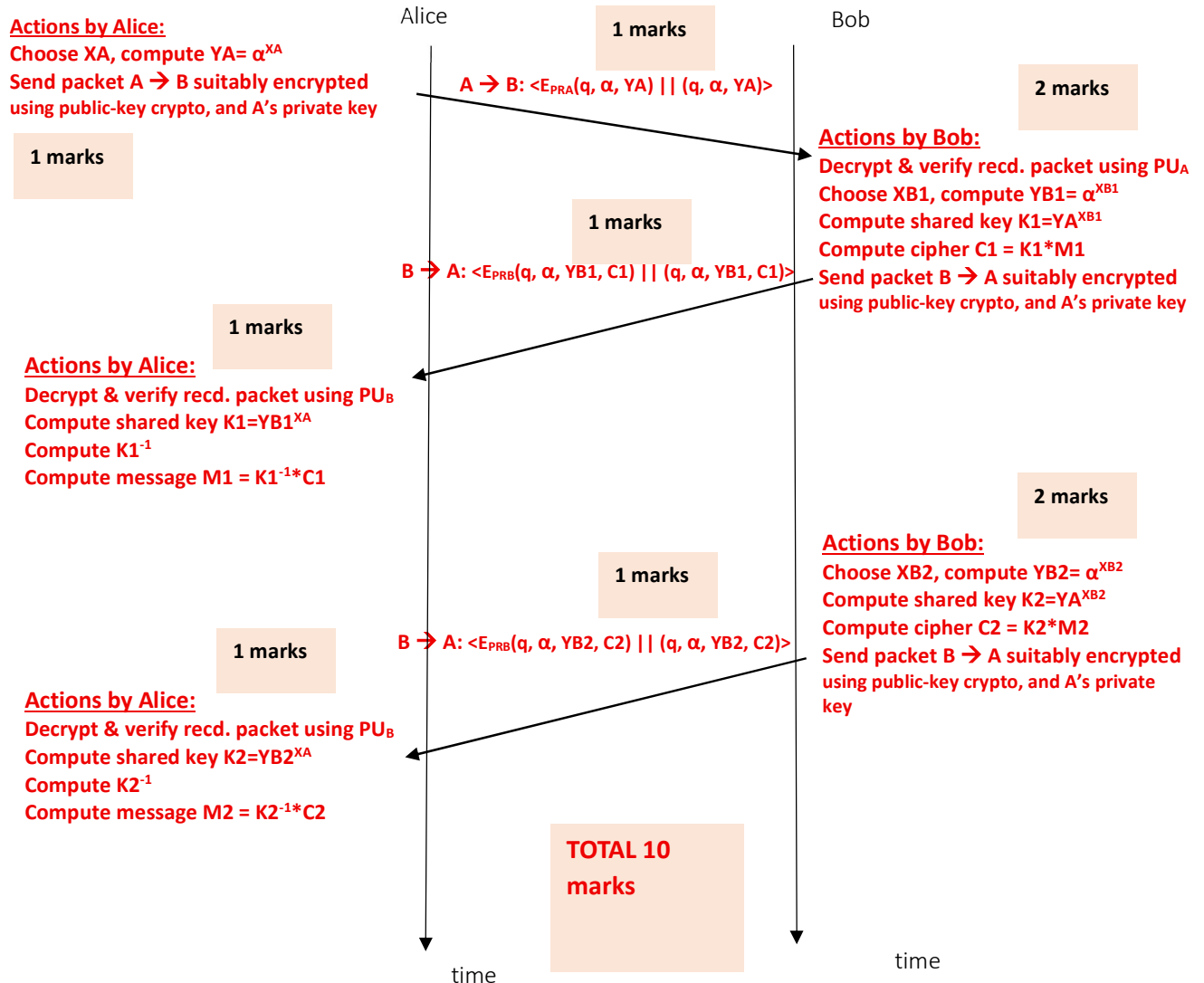
Questions: use the diagram below to indicate:

(A) the sequence of actions taken by Alice or Bob at their ends, and

(B) messages exchanged by Alice & Bob, together with message details in the format given in “Instructions”.

Indicate the nature of encryption scheme that you have used. And be sure to use the correct key(s).

Define any and all terms not defined above.



Q8

8. Consider the working of a “signature” scheme based on **MAC** algorithms, shown below. An intruder would like to launch a **brute-force attack** on this with a view to discover **key K**.



Part of the general procedure goes as follows:

- Let **key size = R**, & **size of MAC value $C(K, M) = N$** . Assume $R = 2N$.
- Assume that an intruder has access to MAC values corresponding to few messages, the intruder has (C_1, M_1) , (C_2, M_2) , etc. Here $C_1 = C(K, M_1)$, $C_2 = C(K, M_2)$, etc.
- **Step 1:** pick (C_1, M_1) and try different values of key to discover a key K_1 such that $C_1 = C(K_1, M_1)$.
- **Step 2:** Etc. etc.

1 1/2 marks for questions A., B., C., D.

4 marks for Question E.

Total 10 marks

Questions:

- A. Is it guaranteed that there will always be a K_1 such that $C_1 = C(K_1, M_1)$?
YES, since $C(K, M)$ was computed using a key, K.
- B. Can there be many such K, viz. K_1, K_2 , etc. such that $C_1 = C(K_1, M_1)$ & $C_1 = C(K_2, M_1)$ & $C_1 = C(K_3, M_1)$ etc.?
YES, since size of $C(K, M)$ is N, smaller than size of key, K.
- C. If your answer to question B above is YES, viz. there may be many K such $C_1 = C(K, M_1)$, then how many such K could there be?
On the average, there will be 2^{R-N} keys K that satisfy $C_1 = C(K, M_1)$,
- D. If your answer to question B above is NO, viz. there will only be one unique K_1 , then has the intruder discovered the correct key $K^* = K_1$ such that $C_1 = C(K^*, M_1)$?
Not applicable, since answer to question B is 'YES'.
- E. If your answer to B above is YES, viz. there may be many K such $C_1 = C(K, M_1)$, then **what is the next step(s)** that will help discover the actual key? List the steps.

Round 2: Call this subset of keys Σ_1 where K is such that $C_1 = C(K, M_1)$. Now, repeat the search with K belonging to Σ_1 . That is search for all K in Σ_1 such that $C_2 = MAC(K, M_2)$. This time it is likely that only one K in Σ_1 will satisfy $C_2 = MAC(K, M_2)$ since $R=2*N$. Otherwise go to Round 3.

Round 3: Call this subset of keys Σ_2 where K is such that $C_1 = C(K, M_1)$, and $C_2 = C(K, M_2)$; and repeat the search with K belonging to Σ_2 . That is search for all K in Σ_2 such that $C_3 = MAC(K, M_3)$. ALMOST SURELY, only one K will satisfy $C_3 = MAC(K, M_3)$ since $R=2*N$.

Roll no.: _____

9. Assume protocol **WPA2** over **TLS/SSL** is used in IEEE 802.11 WiFi networks for client **C** and Access Point (**AP**) to mutually authenticate each other. **Note:** AP is a proxy for the Wireless LAN Controller.

Q9

Questions: Given there does not exist a master key between client **C** and the **AP**. Then

- a. What kind of message should client **C** send to the **AP**, so that **AP** can authenticate client **C**. See example given in "Instructions".

3 marks

C → AP: $\langle E_{PR-C}(ID_C, ID_{AP}, T0) || (ID_C, ID_{AP}, T0) \rangle$ using public-key cryptosystem, and client C's private key, PR-C. ID_{AP} , ID_C are AP's and client's ID, respectively. T0 is current time.

- b. What is that basic information that **AP** must possess to be able to authenticate client **C**?

2 marks

AP must possess client C's public key, PU-C.

- c. What kind of message should **AP** send to the client **C**, so that client **C** can authenticate the **AP**. See example given in "Instructions".

3 marks

AP → C: $\langle E_{PR-AP}(ID_{AP}, ID_C, T1) || (ID_{AP}, ID_C, T1) \rangle$ using public-key cryptosystem, and AP's private key, PR-AP. ID_{AP} , ID_C are AP's and client's ID, respectively. T1 is current time.

- d. What is that basic information that client **C** must possess to be able to authenticate the **AP**?

2 marks

C must possess client AP's public key, PU-AP.

Q10

10. Consider the present day working of the MHS (Message Handling System). It uses SMTP protocol to move email messages from originating MTA (Message Transfer Agent) to the destination MTA.

Questions:

- A. Given the "From:" address, how does the destination MTA determine the **originating ADMD** (Admin Management Domain)?

The destination MTA extracts the domain name following the "@" symbol in the "From:" header to determine the ADMD

- B. Given the **originating ADMD** how does the destination MTA determine whether it is indeed valid?

The MTA looks for at least one MX entry in the DNS server for the given ADMD.

- C. Given the **originating ADMD** has been validated how does the destination MTA determine the **originating MTA**?

The MX record in the DNS corresponding to ADMD identifies one or more servers that act as MTAs for the domain. The DNS server may again be queried to find the IP address of the server or servers that host the MTAs.

- D. To what extent does the destination MTA verify that the received email originated with the **originating ADMD**?

The MTA relies on the DKIM signature in the received mail. If the cryptographic signature is verified using the ADMD's public key, the origin of the mail is confirmed.

- E. To what extent does the destination MTA verify that integrity of headers in the received email have not been altered/compromised?

The DKIM signature contains an encrypted hash of specific requested headers (e.g., From, To, Date, Subject, etc.). The destination MTA hashes these headers itself, decrypts the signature's hash, and compares them. If they match, header integrity is verified

- F. To what extent does the destination MTA verify that the **integrity of the body** of the received email has not been altered/compromised?

The DKIM signature also contains hash value (bh=) of body of the mail. Destination MTA independently hashes the email body and compares it to the bh= value to ensure no transit tampering occurred. Specifically, by default this field is not encrypted or signed.

- G. What **information (say) XXX** must the destination MTA possess before it can begin to verify integrity of headers or the body?

The information XXX is the Public Key of the originating ADMD

- H. If the destination MTA does not possess that **information XXX**, then how does it obtain it?

The destination MTA obtains the Public Key of the originating MTA by executing a DNS query in the DNS table for originating domain, AND using the "selector" specified in the DKIM-Signature header.

1 marks each for A, B, C., D.

2 marks each for E., F.

1 marks each for G., H.

Total 10 marks.

Roll no.: _____

Q11

11. This is about exploring the possibility of breaking into an RSA based public-key cryptosystem. Here is one possibility. In a given public-key cryptosystem, it is known that $n = 391$. Two users, **A** and **B**, are assigned different pairs of public-private keys. The public keys are $PU_A = e_1 = 3$, for user **A**, whereas $PU_B = e_2 = 7$ for user **B**. Their private keys are not known publicly. On one occasion, a user **X** encrypts & sends the same message **M** to both users **A** and **B** using their respective public keys, viz. $PU_A = e_1 = 3$, for user **A**, and $PU_B = e_2 = 7$ for user **B**, to obtain ciphertexts, $C_1 = 147$ and $C_2 = 279$. If an adversary were to get hold of values of C_1 and C_2 , how can he/she figure out message **M**. Note the adversary has only the following information:

$n = 391$, $PU_A = e_1 = 3$, $PU_B = e_2 = 7$, $C_1 = 147$ and $C_2 = 279$. Hint: $e_2 = 2 * e_1 + 1$.

DO NOT try to factor $n = 391$ into its factor. Since n is small, hacking into **M is trivial.**

Show the complete working, viz. how is **M** related to C_1 and C_2 , given that $e_2 = 2 * e_1 + 1$.

Clearly $C_1 = M^{e_1} \bmod n = M^3 \bmod 391 = 147$

And $C_2 = M^{e_2} \bmod n = M^7 \bmod 391 = 279$

2 marks

Since $e_2 = 2 * e_1 + 1$,

$$C_2 = C_1^2 * M \bmod 391,$$

Or $279 = 147^2 * M \bmod 391$

3 marks

→ $M = 279 * (147^{-1})^2 \bmod 391$

Since $147^{(-1)} \bmod 391 = 133$,

2 marks

$$M = 279 * (147^{-1})^2 \bmod 391 = 279 * 133^2 \bmod 391 = 29.$$

3 marks

You can verify that indeed $29^3 \bmod 391 = 147$, and $29^7 \bmod 391 = 279$.

TOTAL 10 marks

	Quotient, Q(i)	Remainder, R(i)	S(i)	T(i)
		$R(i+1) = R(i-1) - Q(i+1)R(i)$	$S(i+1) = S(i-1) - Q(i+1)S(i)$	$T(i+1) = T(i-1) - Q(i+1)T(i)$
0		391	1	0
1		147	0	1
2	2	97	1	-2
3	1	50	-1	3
4	1	47	2	-5
5	1	3	-3	8
5	15	2	47	-125
5	1	1	-50	133